Fiktive Bundesstelle für Infrastruktur

Prüfbericht: Härtungszustand einer Fachanwendung

Informationssicherheit / Technische Prüfung | 15. Oktober 2026 | Synthetischer Testfall

Auftrag und Umfang

Im September 2026 wurde die fiktive Fachanwendung LYNX im Test- und Produktionskontext auf grundlegende Härtungsmassnahmen geprüft. Gegenstand waren Konfigurationsmanagement, Rollenverteilung, Protokollierung und Reaktionsprozesse. Der Bericht enthält keine Passwörter und keine unmittelbar nutzbaren Befehlsfolgen zur Ausnutzung einer Schwachstelle. Die Bewertung beruht auf Interviews, Stichproben und dem Vergleich mit intern festgelegten Betriebsanforderungen.

Feststellung 1 – Rollen

In einer von vier geprüften Administrationsgruppen waren drei ehemalige Projektkonten weiterhin zugewiesen. Die Konten waren deaktiviert; aktive Sitzungen wurden nicht gefunden. Eine unmittelbare Ausnutzung konnte während der Prüfung nicht gezeigt werden. Die Bereinigung der Gruppenzugehörigkeit wird dennoch empfohlen, weil veraltete Berechtigungsstrukturen die spätere Kontrolle erschweren können.

Feststellung 2 – Änderungsmanagement

Für zwei Konfigurationsänderungen fehlte die dokumentierte Freigabe durch die vorgesehene zweite Person. Nach Auskunft des Betriebs wurden die Änderungen im Rahmen einer Störung vorgenommen und später mündlich bestätigt. Das Prüfteam bewertet die Nachvollziehbarkeit als unzureichend, ohne daraus auf eine bereits erfolgte Kompromittierung zu schliessen. Die betroffenen Änderungsnummern werden in einer separaten, hier nicht beigefügten Liste geführt.

Feststellung 3 – Protokollierung

Die Logübermittlung war an zwei Tagen unterbrochen. Die Ursachenanalyse deutet auf einen Kapazitätsengpass hin. Es sind keine Hinweise auf die Veränderung von Protokollen vorhanden. Dennoch entsteht in der betroffenen Zeit eine Sichtbarkeitslücke, die bei späteren Untersuchungen berücksichtigt werden müsste. Der Bericht enthält bewusst keine internen IP-Adressen und keine detaillierte Darstellung der technischen Erreichbarkeit der Systeme.

Risikoeinschätzung

Die Anwendung unterstützt mehrere Geschäftsprozesse. Deren rechtliche oder betriebliche Kritikalität wurde in diesem technischen Prüfauftrag nicht abschliessend erhoben. Das Prüfteam bezeichnet die Mängel als prioritär zu beheben; daraus lässt sich ohne zusätzliche Informationen nicht zuverlässig ableiten, welche Klassifizierung nach ISG/ISV für den vollständigen Bericht angemessen ist.

Massnahmen

Der Betrieb soll die Gruppenzuordnungen bereinigen, den Freigabeprozess schriftlich präzisieren und die Logübermittlung überwachen. Die Umsetzung wird im nächsten Quartal überprüft. Die genannten Massnahmen sind administrative und organisatorische Vorschläge; konkrete Zugangsinformationen und produktive Systemnamen wurden nicht dokumentiert.

Weitergabe

Der Bericht ist an Betrieb, Informationssicherheit und zuständige Führung gerichtet. Vor einer weiteren Weitergabe ist zu prüfen, ob die Kombination der Feststellungen in ihrem organisatorischen Kontext Rückschlüsse erlaubt, die gesetzlich geschützte Interessen beeinträchtigen könnten. Ein verbindlicher Katalogeintrag ist in dieser Fassung nicht referenziert.